

UNIVERSIDAD MAYOR DE SAN ANDRÉS

Carrera de Informática – Seguridad de la Información



Proyecto: Evaluación de seguridad de Módulos de Autenticación Web - Escudo Pet Spa

Nombre del informe: Informe de Pentesting – Evaluación de seguridad y funcionalidad de módulos de autenticación en entorno local

Materia: Taller Técnico Superior

Analista de seguridad: Limachi Tapia Guillermo

Estudiante revisado: Bernas Carrisales Alejandro Ramiro

Fecha: 18/05/26

Clasificación del documento: Académico / Confidencial

Análisis hipotético y planificación ofensiva

1. RESUMEN EJECUTIVO

El presente informe documenta el análisis de superficie de ataque, identificación teórica de vulnerabilidades y simulación de vectores de ataque sobre el sistema "Pet Spa", considerando los módulos correspondientes a Administrador, Recepción, Groomer y Cliente.

Debido a limitaciones del entorno, las evaluaciones fueron realizadas mediante análisis audiovisual del sistema y revisión conceptual de seguridad ofensiva.

2. OBJETIVOS

2.1 Objetivo General

Ejemplo:

Evaluar teóricamente la seguridad del sistema Pet Spa mediante técnicas de reconocimiento, análisis de autenticación, revisión de controles RBAC (Control de Acceso Basado en Roles) y simulación de pruebas de intrusión.

2.2 Objetivos Específicos

- Analizar el sistema de autenticación.
- Evaluar posibles debilidades JWT (JSON Web Token).
- Identificar riesgos de escalación de privilegios.
- Evaluar políticas de contraseñas.
- Detectar malas prácticas visibles.
- Proponer medidas de mitigación.

3. ALCANCE

Aquí defines qué módulos se analizaron.

Ejemplo:

Módulos Evaluados

- Login
- Registro de clientes
- Panel Administrador
- Recepción
- Groomer
- Cliente
- Gestión de usuarios

- Reportes
- Reservas
- Historiales

LIMITACIONES DEL ENTORNO

El análisis realizado corresponde a una evaluación teórica basada en material audiovisual proporcionado por terceros. No se contó con acceso directo al entorno funcional, servidor, base de datos, APIs ni tráfico real de red, por lo que no fue posible ejecutar explotación activa ni validaciones prácticas de vulnerabilidades.

4. METODOLOGÍA

Metodología Utilizada

- Reconocimiento pasivo
- Análisis visual de autenticación
- Evaluación OWASP Top 10
- Simulación de vectores de ataque
- Evaluación RBAC
- Análisis de malas prácticas

5. RECONOCIMIENTO Y SUPERFICIE DE ATAQUE

Hallazgo	Observación	Superficie de ataque	Vulnerabilidad teórica	Pruebas hipotéticas	Simulación de ataque	Riesgo	Impacto	Severidad	Mitigación	Mejora recomendada
Creación de cuentas administrativas desde login público	El sistema permite acceder al módulo de creación de administradores desde el login inicial.	Login público, formularios administrativos	Exposición crítica de funciones privilegiadas	OSINT, fuzzing de rutas, manipulación de formularios	Un atacante podría descubrir endpoints administrativos y crear cuentas privilegiadas.	Compromiso total del sistema	Crítico	Crítica	Restringir acceso a módulos administrativos	Mover creación de administradores a entorno interno protegido
Ausencia de CAPTCHA en login y registro	No existe CAPTCHA en autenticación ni en creación de cuentas.	Login, registro público	Automatización de ataques y fuerza bruta	Credential stuffing, bots, rotación IP	Un atacante podría automatizar accesos y registros maliciosos.	Compromiso de cuentas y saturación de recursos	Alto	Alta	CAPTCHA adaptativo y rate limiting	Implementar reCAPTCHA y monitoreo de comportamiento
Registro masivo de clientes sin validación efectiva	Los clientes pueden registrarse ilimitadamente aun sin activar la cuenta.	Registro público, BD	Contaminación masiva de la base de datos	Flood de registros, bots automatizados	Un atacante podría llenar la BD con cuentas falsas no verificadas.	Saturación de BD y degradación del sistema	Alto	Alta	Límite de registros y limpieza automática	Eliminar cuentas no verificadas automáticamente
Creación de empleados sin validaciones estrictas	Los formularios permiten ingresar información arbitraria sin restricciones visibles.	Panel administrativo, formularios internos	Corrupción de datos y almacenamiento de payloads maliciosos	Inputs inválidos, XSS, caracteres especiales	Un atacante podría almacenar información maliciosa o inconsistente.	Corrupción de datos y XSS	Alto	Alta	Sanitización y validación backend	Aplicar validación tipada y sanitización centralizada
Contraseñas por defecto sin cambio obligatorio	Las cuentas de empleados reciben contraseñas predeterminadas y quedan activas inmediatamente.	Gestión de empleados, autenticación	Uso de credenciales predecibles	Fuerza bruta dirigida, uso de passwords por defecto	Un atacante podría acceder usando contraseñas conocidas o fáciles de deducir.	Acceso indebido a cuentas internas	Crítico	Crítica	Cambio obligatorio de contraseña y MFA	Forzar restablecimiento en primer login
Recuperación de contraseña insuficientemente protegida	El módulo solo solicita correo y código sin CAPTCHA ni verificación adicional.	Recuperación de cuentas	Abuso del sistema de recuperación	Enumeración de correos, phishing, fuerza bruta de códigos	Un atacante podría automatizar recuperación de cuentas o secuestrar accesos.	Secuestro de cuentas	Alto	Alta	CAPTCHA y MFA en recuperación	Agregar validaciones de riesgo y confirmación multifactor
Sistema de logs sin SIEM	Los logs se almacenan en la BD y no cuentan con SIEM.	Logs, auditoría, BD	Limitada detección de incidentes y manipulación de registros	Alteración de logs, eliminación de evidencias	Un atacante privilegiado podría modificar registros sin trazabilidad avanzada.	Pérdida de auditoría y monitoreo	Alto	Alta	Logs inmutables y SIEM	Implementar SIEM centralizado
Contraseñas protegidas mediante hashing	Las contraseñas están almacenadas utilizando hashing.	Base de datos y autenticación	No se observa vulnerabilidad directa en almacenamiento	Evaluación del algoritmo hash	Ante filtración de la BD, el hashing dificulta cracking offline.	Bajo riesgo directo	Bajo	Baja	Mantener algoritmos modernos	Migrar a Argon2id y complementar con MFA

6. RECOMENDACIONES GENERALES Y CONCLUSIONES ESPECIFICADA POR CASOS

Hallazgo 1 — Creación de cuentas administrativas desde el login público

Observación

El sistema permite visualizar y acceder al módulo de creación de cuentas administrativas desde el login inicial público.

Superficie de ataque

- Login público
- Registro administrativo
- Formularios de creación de cuentas

Vulnerabilidad teórica

Exposición crítica de funcionalidades administrativas accesibles desde superficie pública.

Pruebas hipotéticas

- Enumeración de rutas administrativas
- Descubrimiento mediante OSINT
- Fuerza bruta sobre endpoints administrativos
- Manipulación de formularios de registro

Simulación de ataque

Un atacante podría identificar endpoints administrativos públicos utilizando herramientas OSINT o fuzzing y explotar fallas de validación para intentar crear cuentas privilegiadas.

Riesgo

- Creación indebida de administradores
- Compromiso total del sistema
- Escalación de privilegios

Impacto: Crítico

Severidad: Crítico

Mitigación

- Eliminar accesibilidad pública a creación administrativa
- Restringir rutas administrativas
- Segmentar módulos internos

Mejora recomendada

Mover completamente la creación de administradores a entornos internos protegidos mediante RBAC y MFA.

Hallazgo 2 — Ausencia de CAPTCHA en autenticación y registros

Observación

El sistema no implementa CAPTCHA en login ni en registro de clientes.

Superficie de ataque

- Login
- Registro público
- Formularios de autenticación

Vulnerabilidad teórica

Posibilidad de automatización de ataques de fuerza bruta y creación masiva de cuentas.

Pruebas hipotéticas

- Credential stuffing
- Fuerza bruta
- Flood de registros
- Rotación de IP

Simulación de ataque

Un atacante podría automatizar accesos y registros utilizando bots para comprometer cuentas o saturar la base de datos.

Riesgo

- Compromiso de cuentas
- Saturación de recursos
- Denegación parcial de servicio

Impacto: Alto

Severidad: Alto

Mitigación

- CAPTCHA adaptativo
- Rate limiting
- Monitoreo de comportamiento sospechoso

Mejora recomendada

Implementar reCAPTCHA y controles de reputación IP/dispositivo.

Hallazgo 3 — Registro masivo de clientes sin validación efectiva previa

Observación

Los clientes pueden registrarse ilimitadamente aun sin validar el código de activación.

Superficie de ataque

- Registro público
- Base de datos
- Gestión de usuarios

Vulnerabilidad teórica

Posible contaminación masiva de la base de datos mediante cuentas no verificadas.

Pruebas hipotéticas

- Bots automatizados
- Flood de registros
- Creación masiva de cuentas falsas

Simulación de ataque

Un atacante podría generar miles de registros no activados saturando la base de datos y degradando el rendimiento del sistema.

Riesgo

- Saturación de BD
- Crecimiento descontrolado de registros
- Degradación del servicio

Impacto: Alto

Severidad: Alto

Mitigación

- Límite de registros por IP
- Eliminación automática de cuentas no verificadas
- CAPTCHA

Mejora recomendada

Implementar limpieza automática de cuentas pendientes y validación previa antes de persistir registros.

Hallazgo 4 — Creación de empleados sin validaciones estrictas

Observación

El administrador puede crear empleados ingresando información arbitraria sin validaciones visibles.

Superficie de ataque

- Panel administrativo
- Formularios internos
- Gestión de empleados

Vulnerabilidad teórica

Posible corrupción de datos o almacenamiento de payloads maliciosos.

Pruebas hipotéticas

- Inserción de scripts
- Inputs inválidos
- Caracteres especiales
- Datos excesivamente largos

Simulación de ataque

Un atacante con acceso administrativo podría almacenar información maliciosa o inconsistente afectando integridad y seguridad.

Riesgo

- Corrupción de datos
- XSS almacenado
- Inconsistencia lógica

Impacto: Alto

Severidad: Alto

Mitigación

- Validaciones backend
- Sanitización
- Restricciones de formato

Mejora recomendada

Aplicar validación tipada obligatoria y sanitización centralizada.

Hallazgo 5 — Asignación de contraseñas por defecto sin cambio obligatorio

Observación

Las cuentas de empleados son creadas activas y reciben una contraseña por defecto sin requerir cambio obligatorio al primer inicio de sesión.

Superficie de ataque

- Gestión de empleados
- Sistema de autenticación

Vulnerabilidad teórica

Exposición a uso de credenciales predecibles o reutilizadas.

Pruebas hipotéticas

- Uso de contraseñas por defecto
- Fuerza bruta dirigida
- Enumeración de usuarios

Simulación de ataque

Un atacante podría intentar acceder utilizando contraseñas predeterminadas conocidas o fácilmente deducibles.

Riesgo

- Acceso indebido
- Compromiso de cuentas internas

Impacto: Crítico

Severidad: Crítico

Mitigación

- Cambio obligatorio de contraseña
- Contraseñas temporales aleatorias
- MFA

Mejora recomendada

Forzar restablecimiento de contraseña en primer login y activar MFA obligatorio.

Hallazgo 6 — Recuperación de contraseña insuficientemente protegida

Observación

El módulo “Olvidé mi contraseña” solo solicita correo electrónico y código de verificación sin CAPTCHA ni validación adicional de identidad.

Superficie de ataque

- Recuperación de cuentas

- Restablecimiento de contraseña

Vulnerabilidad teórica

Posible abuso del sistema de recuperación mediante automatización o interceptación de códigos.

Pruebas hipotéticas

- Enumeración de correos
- Automatización de recuperación
- Ataques de phishing
- Fuerza bruta de códigos

Simulación de ataque

Un atacante podría automatizar solicitudes de recuperación o intentar comprometer cuentas mediante ingeniería social.

Riesgo

- Secuestro de cuentas
- Acceso no autorizado

Impacto: Alto

Severidad: Alto

Mitigación

- CAPTCHA
- MFA en recuperación
- Expiración corta de códigos
- Límite de intentos

Mejora recomendada

Agregar validaciones de riesgo y confirmación multifactor para recuperación de credenciales.

Hallazgo 7 — Sistema de logs limitado a base de datos sin SIEM

Observación

Los logs y auditorías son visibles desde el panel administrativo pero continúan almacenándose directamente en la base de datos sin integración SIEM.

Superficie de ataque

- Logs

- Auditoría
- Base de datos

Vulnerabilidad teórica

Capacidad limitada de monitoreo avanzado y detección temprana de incidentes.

Pruebas hipotéticas

- Alteración de logs
- Eliminación de registros
- Accesos indebidos a auditoría

Simulación de ataque

Un atacante con privilegios elevados podría modificar registros sin mecanismos avanzados de integridad o correlación de eventos.

Riesgo

- Pérdida de trazabilidad
- Encubrimiento de actividad maliciosa

Impacto: Alto

Severidad: Alto

Mitigación

- SIEM
- Logs inmutables
- Alertas automáticas

Mejora recomendada

Implementar SIEM centralizado y almacenamiento externo seguro de auditorías.

Hallazgo 8 — Contraseñas protegidas mediante hashing

Observación

Las contraseñas se encuentran almacenadas utilizando hashing.

Superficie de ataque

- Base de datos
- Sistema de autenticación

Vulnerabilidad teórica

No se evidencia vulnerabilidad directa relacionada al almacenamiento de contraseñas.

Pruebas hipotéticas

- Validación de algoritmo hash
- Evaluación de resistencia offline

Simulación de ataque

Ante filtración de la base de datos, el hashing dificulta ataques de cracking directo.

Riesgo: Bajo

Severidad: Baja

Impacto: Positivo

Mitigación

- Mantener algoritmos modernos
- Incrementar costo computacional

Mejora recomendada

Migrar a Argon2id y complementar con MFA obligatorio.

